# Tabel Akses & Catatan Risiko

Aplikasi Biro Umum dan Rumah Tangga · dibuat 5 November 2026

## 1 · Tabel akses

Siapa boleh melakukan apa. Baris = peran pengguna, kolom = tindakan.

| Peran \ Tindakan | Lihat jadwal ruang rapat | Buat booking ruang rapat | Edit / batal booking ruang rapat | Ajukan Pemeliharaan / Pengadaan | Edit / hapus Pemeliharaan / Pengadaan | Lihat data kendaraan | Tambah / ubah / hapus kendaraan | Kelola akun, Maintenance, Riwayat |
|---|---|---|---|---|---|---|---|---|
| **Tamu (login Google)** | Boleh | Boleh | Hanya miliknya | Tidak | Tidak | Tidak | Tidak | Tidak |
| **Karyawan** | Boleh | Boleh | Boleh | Boleh | Tidak | Boleh | Tidak | Tidak |
| **PIC** | Boleh | Boleh | Boleh | Boleh | Hanya miliknya | Boleh | Tidak | Tidak |
| **Kabag** | Boleh | Boleh | Boleh | Boleh | Boleh | Boleh | Boleh | Boleh |
| **Admin** | Boleh | Boleh | Boleh | Boleh | Boleh | Boleh | Boleh | Boleh |

**Catatan:**

• **Tamu** masuk lewat login Google di kiosk (sesi 7 hari), tidak bisa membuka aplikasi internal. Booking baru wajib captcha. “Hanya miliknya” pada edit/batal berarti hanya pengajuan atas akun Googlenya sendiri, dan hanya selama belum berjalan.

• **Ruang rapat:** semua pegawai (karyawan, PIC, Kabag, Admin) sengaja boleh mengelola semua booking, termasuk surat dan statusnya.

• **PIC** adalah karyawan yang otomatis naik peran setelah mengajukan Pemeliharaan/Pengadaan pertamanya. “Hanya miliknya” = data yang ia tambahkan sendiri.

• **Kolom terakhir** mencakup menu Akun & Akses, Mode Maintenance, Riwayat Aktivitas, serta foto dan daftar ruangan. Kabag setara Admin, kecuali akun **Admin** tidak bisa diubah oleh Kabag (ubah peran, blokir, link reset kata sandi, verifikasi email).

• Pembatasan ini diterapkan di **server**, bukan hanya dengan menyembunyikan tombol di tampilan.

## 2 · Tiga catatan risiko

Dua risiko keamanan dan satu risiko sistem gagal. Tiap risiko: apa yang terjadi, akibatnya, cara mencegah, dan cara menguji.

### Risiko 1 · Keamanan: tamu mengakses booking milik tamu lain (IDOR)

| | |
|---|---|
| **Apa yang terjadi** | ID booking berupa angka berurutan. Tamu yang sudah login bisa mengganti ID pada `PUT /api/guest/bookings/:id` atau `POST /api/guest/bookings/:id/cancel` dengan ID milik tamu lain lalu mengubah atau membatalkan booking itu. |
| **Akibat** | Booking orang lain berubah atau batal tanpa izin, ruangan bisa dikosongkan atau diambil, dan tamu yang dirugikan tidak tahu penyebabnya. Merusak kepercayaan pada sistem booking. |
| **Cara mencegah** | Setiap query di backend selalu menyertakan `guest_id` tamu yang sedang login (bukan hanya ID booking). Booking milik orang lain diperlakukan sebagai tidak ada: respons **404**, bukan 403, sehingga ID yang valid tidak bisa ditebak. Pemeriksaan dilakukan di server; menyembunyikan tombol di tampilan saja tidak dianggap cukup. |
| **Cara menguji** | Login sebagai tamu A dan tamu B. Buat satu booking dengan tamu B dan catat ID-nya. Dengan token tamu A, panggil PUT edit dan POST cancel ke ID itu. **Hasil yang benar:** keduanya 404, dan booking tamu B tidak berubah (cek di kartu “Booking Anda” milik B dan di riwayat aktivitas). |

### Risiko 2 · Keamanan: pegawai memanggil API di luar wewenang perannya (akses lintas peran)

| | |
|---|---|
| **Apa yang terjadi** | Karyawan atau PIC tidak melihat tombol Edit/Hapus di aplikasi, tetapi memanggil API langsung (lewat browser DevTools atau alat seperti Postman) — misalnya `PUT /api/pemeliharaan/:id` milik PIC lain, atau `POST /api/kendaraan`. |
| **Akibat** | Data pemeliharaan, pengadaan, atau kendaraan orang lain bisa diubah atau dihapus. Riwayat tetap mencatat siapa pelakunya, tetapi kerusakan data sudah terjadi. |
| **Cara mencegah** | Wewenang dicek di server pada setiap request: `requireRole` untuk peran (Pemeliharaan/Pengadaan: kabag, pic, admin; Kendaraan dan Akun & Akses: admin dan kabag), ditambah aturan “hanya miliknya” untuk PIC yang membandingkan `created_by` dengan ID pengguna login. Peran dibaca dari database pada tiap request, jadi perubahan peran langsung berlaku tanpa login ulang. |
| **Cara menguji** | Dengan token **karyawan**: PUT dan DELETE ke data Pemeliharaan, lalu POST ke Kendaraan. Dengan token **PIC B**: PUT ke data buatan PIC A. **Hasil yang benar:** semua ditolak 403 dan data tidak berubah. Ulangi dengan token Kabag untuk memastikan yang seharusnya boleh memang lolos. |

### Risiko 3 · Sistem gagal: SMTP bermasalah, sehingga email konfirmasi dan pengingat tidak terkirim

| | |
|---|---|
| **Apa yang terjadi** | Server email (Gmail/SMTP) menolak login, kena batas kirim, atau tidak bisa dihubungi. Email konfirmasi, pembatalan oleh Biro Umum, dan pengingat booking tidak sampai ke tamu. |
| **Akibat** | Tamu tidak tahu booking-nya dibatalkan dan datang sia-sia, atau lupa jadwalnya sehingga ruangan terpakai kosong. Bila pengiriman email ikut menggagalkan simpan booking, tamu juga tidak bisa memesan sama sekali. |
| **Cara mencegah** | Email dikirim di latar belakang: kegagalannya tidak menggagalkan simpan atau batal booking, hanya dicatat di log. Pengingat yang gagal dilepas klaimnya dan dicoba lagi sampai 3 kali. Pengiriman dilakukan hanya bila SMTP di .env terisi. Sumber kebenaran tetap kartu “Booking Anda” di kiosk, bukan email. Keterbatasan: penghitung percobaan ada di memori, jadi hilang bila backend restart. |
| **Cara menguji** | Isi `SMTP_PASS` dengan nilai salah, restart backend, lalu ajukan, edit, dan batalkan booking. **Hasil yang benar:** semua tetap berhasil (201/200), dan log memuat peringatan “Email booking tamu gagal dikirim”. Kosongkan `SMTP_HOST` untuk memastikan fitur email diam tanpa error. |